Android APKの静的解析と動的通信解析を併用した差分説明支援システム

URI入力切替による差分説明の補強と29試行の事例評価（卒業論文草稿）

著者名・所属・学籍番号：提出時に記入

2026年11月6日改訂
仮説・判定基準と最終結果の整理版

概要

APK内の通信先候補と実行時通信の差を説明するため，静的解析と指定操作下の通信観測を併用する支援システムを実装した。候補と実測の対応，判断に不足する情報，根拠を同時に示し，局所的な引数追跡とURI入力切替で説明を補強する。AntennaPodの対応API 29箇所では定数引数2箇所，不明27箇所であった。一方，A・B・B・Aの入力切替4試行すべてで，対象UIDの要求先ポートが入力先と一致した。これにより，静的候補にない通信について，登録した入力条件との対応を実験記録で説明できた。既存25試行は取得・帰属・差分の補助事例として整理した。評価は公開アプリ1本・単一AVDを中心とする事例研究であり，コード経路の確定や一般的な精度向上は評価対象と区別する。

キーワード：Android，APK，静的解析，動的通信解析，差分説明，証拠追跡性

利用にあたって　本稿は目的・方法・結果・考察・結論を備えた卒業論文草稿であり，提出確定版ではない。既存実験の事後評価とAI支援による点検を明記し，独立した正解や方法上の新規性を架空に補わない。著者情報，大学の形式，指導教員による研究範囲の確認を経て提出版とする。

目次

1 研究背景と問題設定 4
1.1 APKの情報と実行時通信を別々に読む難しさ 4
1.2 静的解析と動的観測の相補性 4
1.3 研究目的と主張の範囲 4
1.4 対象利用者・脅威モデルと本研究で実施したこと 4

2 技術的基盤と既存ツールとの関係 5
2.1 APKと静的な証拠 5
2.2 Androidの通信設定 5
2.3 通信観測ツール 5
2.4 公式実装資料に基づく方式の比較 5
2.5 自動実行とポリシー照合に関する先行研究 6
2.6 査読論文本文に基づく比較 6
2.7 差分通信解析と端末上の通信観測 7

3 理論モデル 7
3.1 入力と証拠の形式化 7
3.2 静的候補と実測の対応・差分モデル 8
3.3 差分を説明する情報の分離 8
3.4 使用文脈と追加観測による差分説明 8
3.5 任意ポリシーの明示性 10
3.6 部分情報に基づく判定 10
3.7 独立した観測軸 10
3.8 ホスト名照合と未知値 11
3.9 アプリ帰属 11
3.10 操作との時間的対応 11
3.11 未観測の条件 11
3.12 時刻の不確実性と実装範囲 12

4 システム設計 12
4.1 構成とデータの流れ 12
4.2 記号と実装の対応 12
4.3 静的解析手順 13
4.4 動的取得と操作管理 13
4.5 ログアダプタ 13
4.6 補助機能のポリシー照合規則 14
4.7 証拠の管理と再現性 14

5 実装と利用方法 15
5.1 実装環境とモジュール 15

5.2 標準的な実行例 15
5.3 使用文脈解析とURI対照ランナー 16
5.4 資源制限と入力保護 16
5.5 記録保護と共有版 16

6 評価方法 16
6.1 研究課題 16
6.2 研究デザインとデータの範囲 17
6.3 比較する入力と手法 17
6.4 評価単位と指標 17
6.5 開始状態と操作記録の扱い 18
6.6 妥当性への脅威 18
6.7 差分説明の確認基準 18

7 評価結果 18
7.1 局所的な静的引数追跡の結果 18
7.2 URI入力切替による要求先の追随 19
7.3 静的・動的差分を中心とした再解析 19
7.4 対応と差分から得られた説明 20
7.5 併用と補助的な照合の結果 20
7.6 点検と一般化の範囲 21

8 考察と制約 21
8.1 静的候補・実測・入力切替が担う役割 21
8.2 取得の不確実性を残す意義 21
8.3 比較から確認できた範囲 21
8.4 妥当性と次に確かめること 21

9 結論 22

10 倫理とデータ管理 22

A 素材同定と実装確認 23
A.1 APKと環境の同定 23
A.2 開発用の静的確認 23

B 最終台帳と取得範囲 24
B.1 最終データ構成 24
B.2 確認済み範囲と拡張課題 24

C 再現資料とAI支援の記録 25

1　研究背景と問題設定

1.1　APKの情報と実行時通信を別々に読む難しさ

Androidアプリは，自ら実装した処理だけでなく，ライブラリ，SDK，OSサービスとの連携を含む。たとえば「端末内で記録を保存する」という目的のアプリでも，ビルド設定や依存関係によって広告・解析用のコードや通信権限が含まれる可能性がある。AIによるコード生成の利用は，開発者がすべての依存や初期化経路を把握していない状況の一例となる。ただし，本研究ではAI生成アプリの方が危険であると事前に仮定しない。生成手段と不一致の発生頻度の関係は，条件を統制した別途の評価が必要である。

静的解析のURL一覧と通信キャプチャの一覧を別々に示すだけでは，同じ相手を示す情報の対応，実行時入力で増える通信，取得不足の区別を利用者が行う必要がある。本研究は，この対応と差分の説明を主課題とする。追加機能として明示ポリシーを入力できるが，開発者の意図を自動推定する機能ではなく，差分説明の必須入力にも含めない。

1.2　静的解析と動的観測の相補性

静的解析は，実行しなかった経路を含むコードや宣言を調べられる一方，未使用のURLやSDKの残存コードも候補に含める。動的観測は実際に起きた通信の証拠を得られる一方，操作，待機時間，ネットワーク条件に依存し，観測されなかった経路を網羅できない。両方式は単独では結論できない点が異なるため，証拠を統合する意義がある。

1.3　研究目的と主張の範囲

目的は，単一APKを入力として静的解析と指定操作下の動的通信解析を実行し，両者の対応・差分・判断不足を原本へ戻れる形で説明するシステムを構築・評価することである。動的解析は通信観測と操作・取得条件の記録を指し，任意の全機能探索を意味しない。静的候補と実測がなぜ違うかについて，記録で確認できる事実と未確認の可能性を分離する。実装の成立と説明範囲を評価し，全アプリの完全解析，原因の自動確定，安全性判定，判定精度の向上を目的の達成と同一視しない。

対象は，解析・実行の権限がある単一APKである。split APK・AAB，ネイティブコードの意味解析，動的ロードや高度な難読化への対処は初期実装の範囲外とする。

1.4　対象利用者・脅威モデルと本研究で実施したこと

対象利用者は，善意でアプリを開発しているが依存や設定を完全には把握していない開発者を想定する。意図的な解析回避を行うマルウェア，高度な難読化，ネイティブ実装の意味解析は保証範囲に含めない。外部収集器の自己申告を原本の真実性の保証とは扱わず，独立したアプリ・サーバ記録で補強する。

本研究で実施した内容は，(1)静的解析と実行管理・通信解析を単一入口に接続したシステムの実装，(2)確認事実・不足・原因候補と原本参照を持つ差分説明の実装，(3)URI切替4試行による入力先と対象要求の対応の確認，および既存25試行による取得・帰属・差分の整理である。中心的な研究課題は，静的候補に現れない実測の説明を，登録入力と追加観測によってどこまで補強できるかである。成果は具体的な設計と再解析可能な事例評価として示す。

2　技術的基盤と既存ツールとの関係

2.1　APKと静的な証拠

APKはZIPコンテナであり，Manifest，DEX，リソース，署名関連ファイル等を含む。Manifestはパッケージ名，SDK条件，権限，コンポーネント，通信セキュリティ設定への参照を宣言する。DEXの文字列・クラス・命令参照は，URL候補やSDK特徴を探す資料となる。AndroguardはAPK・AXML・DEX等を扱う解析ライブラリであり，本実装では版を固定して利用する[1]。

2.2　Androidの通信設定

平文通信やCA信頼の扱いは，実行OS，target SDK，Manifest属性，Network Security Configに依存する[2]。Android API 24以降のNSCを利用する場合，Manifestの平文フラグだけから有効設定を決めない。ドメイン別設定には継承があり，ベース設定と例外を保存する必要がある。また，設定上の平文許可と実際にHTTP等を観測した事実は別の指摘である。

標準設定におけるユーザーCAの信頼はtarget SDKに依存する。設定画面にCAが存在することだけでは，対象アプリがそのCAを信頼するとはいえない。独自CAストアやピンニングは追加の制約となる。本システムのメタデータ観測では，CA導入やAPKの再署名を必須としない。

2.3　通信観測ツール

Emulatorのパケット取得は仮想ネットワークの通信を記録できる[3]が，通常のPCAPだけでは対象アプリのUIDが得られない。PCAPdroidはVPN方式のアプリ情報付き通信観測を提供する既存ツールである[4]。現実装は2.0.2のCSVとUID拡張付きPCAPを扱う。CSVの列契約と対象UIDの記録，および自動取得PCAPのUIDとインストール記録の整合を確認した。独立した帰属精度の推定は別の評価とする。

mitmproxyによるHTTP/HTTPSの詳細取得は補助的な手段である。Android System ProxyとEmulator Proxyは役割が異なり，一部アプリはSystem Proxyを経由しない[5]。HTTP/3等の対応も利用モードに制約がある[6]。したがって，復号できなかったことと通信が発生しなかったことを区別しなければならない。

既存ツールが収集した証拠を開発意図の明示性と結び付け，不明・未観測・失敗を維持したまま根拠付きの結果に変換する点が，本システムの設計上の焦点である。研究上の新規性を主張する際は，意図ベースの監査，モバイルアプリのプライバシー分析，SDK検出，通信帰属に関する査読文献を追加調査し，比較する必要がある。

2.4　公式実装資料に基づく方式の比較

FlowDroidの公式資料は，Android/Javaにおけるsourceからsinkへの静的データフロー解析と，解析対象の定義・SDK JAR・タイムアウト等を説明している[8]。本システムの局所的な文字列引数追跡と，メソッドをまたぐsource-to-sink解析は範囲が異なる。LibScoutは元ライブラリから作成したプロファイルでライブラリと版を識別し，難読化等を考慮する[9]。本実装は接頭辞等のルールによる候補検出を担当し，実SDKの識別評価は別に必要とする。

PCAPdroidの固定ソースを調べると，CSVはUID，package，通信量，時刻等を含む一方，表示用状態が複数の内部状態をまとめ，Info列もSNI/DNS/HTTP等の出典を保持しない[10]。本実装はその欠落を不明として保持する。これらの公式README・ソースの確認と，

査読論文本文の確認は区別する。PoliCheckとPoliGraphは提供された本文の関連節を確認した。関連研究全体の網羅性と方法上の新規性は確定していない。

2.5 自動実行とポリシー照合に関する先行研究

DroidBotは，ADB経由で端末情報を取得し，実行時に構築する状態遷移モデルから入力を生成する非計装のテスト入力生成器である[14]。論文はUI階層，ログ，スクリプトと実行経路の観測範囲を扱っている。本システムの起動・タップ・待機はこの分野の既存技術であり，自動操作そのものを貢献とはしない。MobSFも静的・動的解析とAPI・CLI連携を提供する既存ツールである[16]。APKを入力して両解析を実行しHTMLを出すことだけでは，研究上の新規性の根拠として不十分である。

PurPlianceは，プライバシーポリシーと通信から抽出・推定したデータ利用目的の整合性を分析する[15]。同論文6.3節は，目的が未指定の場合にその条件を検査しないと定め，8.1節と9節は入力生成で通信を起こせない場合，ログイン，証明書ピンニングによる観測制約を述べる。従って，目的を含む照合，未指定の条件を暗黙に禁止としないこと，未観測の限界を述べること自体は本研究の独占的な貢献としない。本システムは利用目的を通信から推定せず，利用者が宣言する条件を入力とする。この違いは意味推定を省く設計選択であり，PurPlianceと同等の目的推定や性能を実装したとはいえない。

PoliCheckは受信主体とデータ型のフローをプライバシーポリシーへ照合し，clear・vague・omitted・incorrect・ambiguousの5種類を定義する[19]。3.1節のentityは主にデータの受信組織であり，本実装の送信元AndroidアプリのUID帰属と区別する。5.2.1節では人手検証の候補180フローから不確かな27を分けて153を評価し，ambiguous開示も当該検証の対象外とした。不明・判断困難の扱い自体に先行例がある。

PoliGraphは文をまたぐ関係を知識グラフとして表し，3.3節では未指定データ・第三者の特別なノードを設ける[20]。4.1.2節は辺の生成元の文の保存を，7節は誤推論・抽出漏れ・人手検証の必要性を述べる。これはポリシー文の意味表現であり，UID不明や取得失敗と同じ概念ではない。根拠追跡や不完全性の区分という一般的特徴だけを新規性としない。公式実装の確認も補助資料として区別する[17, 18]。

以上を踏まえ，本研究の中心は，静的候補と指定操作下の実測を対応付け，差分の説明を原本で確認できるようにする実装と事例評価である。自然言語ポリシー照合は近接分野であり，送信目的の推論や既存ツールとの性能比較を実施したことにはしない。この焦点自体が未研究であるとはまだ主張しない。既存ツールに対する性能優越や，新しいデータフロー解析・SDK検出アルゴリズムの提案は対象外とする。

2.6 査読論文本文に基づく比較

対象	本文で確認した内容	本研究への位置付け
PoliCheck	受信主体とデータ型のフローを5種類の開示状態へ分類。人手検証で不確かな27フローを分ける。	受信組織の識別は送信元アプリのUID帰属と異なる。複数状態や保留自体を新規としない。
PoliGraph	未指定データ・第三者の表現，辺の生成元の文を保存。局所・大域オントロジーを区別し，文をまたぐ関係を推論。	本実装は同じ自然言語推論を行わない。未指定の区分と根拠へ戻る機能自体は既存の概念である。

評価の範囲	PoliCheckは判断困難例を区別した人手検証。PoliGraphは比較データ型と主体粒度をそろえた抽出評価，過去の通信と当時のポリシーによる照合。	25端末試行をこれらの適合率・再現率と直接比較しない。こちらの人手注釈は未取得。

PoliCheck 3.1節・3.3節・5.2.1節・7節，PoliGraph 3.3節・4.1.2節・4.2節・5.4節・7節を含む関連本文を確認した[19, 20]。PoliCheckのomitted disclosureは観測済みデータの開示欠落であり，本実装のポリシーJSON未指定とは異なる。PoliGraphのunspecifiedもポリシー文の意味表現であり，UID不明や取得失敗と同じ状態ではない。

PoliGraph 4.1.2節は辺の生成元の文の保存を明記し，7節は誤推論・抽出漏れと人手確認の必要性を述べる。従って「不明を扱う」「根拠へ戻れる」「未観測を断定しない」という一般的特徴だけで方法上の新規性は主張しない。両論文本文の未取得は提供PDFにより解消したが，関連研究の網羅性や本実装の方法上の新規性が確定した意味ではない。

2.7 差分通信解析と端末上の通信観測

Agrigentoの公式資料は，アプリの基準通信を得た後，端末IDや位置情報等の入力源を変更し，通信の変化からプライバシー漏えいを調べる方式を説明している[21]。乱数，時刻，セッション識別子等の非決定性を抑えるため，API呼び出しの記録・再生や値の置換を用いる。したがって，入力を変えて通信を比較すること自体には明確な先行例がある。本研究は研究用URIを明示入力し，静的候補との差分説明を補強する限定した事例を扱う。Agrigentoと同じ情報漏えい検出や非決定性抑制を実装したものではない。

AntMonitorの公式資料は，Android上のVPNによるパケット取得・検査と，そのライブラリ化を説明している[22]。端末上の通信観測やその実装も先行技術である。本稿の焦点は，取得ツールを新規に提案することではなく，APK内候補・指定入力・観測・証拠参照を結び付けた差分説明である。ここでは固定した公式READMEの確認範囲を引用し，両研究の論文本文や比較実験まで確認したとは扱わない。

3 理論モデル

3.1 入力と証拠の形式化

APKを A，任意の明示ポリシーを I，操作シナリオを U，観測条件を C とする。静的候補集合 S と動的証拠集合 D を別々に取得し，差分説明 X を構成する。追加の規則判定 F は I を与える場合の別出力である。

$$S = f_{\text{static}}(A, R_s), \tag{1}$$

$$D = f_{\text{capture}}(A, U, C), \tag{2}$$

$$X = h(S, D, U, C, R_m), \tag{3}$$

$$F = g(I, S, D, R_c), \tag{4}$$

ここで R_s は静的特徴ルール，R_m は通信先対応と説明の規則，R_c は任意ポリシーの照合ルールである。S は実行事実を意味しない。D は条件 C に依存するため，別の操作や待機条件で通信が生じないことを保証しない。

各証拠 e を，出典，場所，時刻，観測段階，帰属，本文可視性からなる組として保存する。

$$e = (\text{id}, \text{source}, \text{locator}, t_0, t_1, o, a, v). \tag{5}$$

静的証拠では時刻は実行時刻を表さず，DEXの文字列番号や命令オフセット，Manifest内の宣言を所在とする。逆コンパイル結果の位置を原ソースの行番号とは扱わない。

3.2 静的候補と実測の対応・差分モデル

静的URL文字列はホストとポートで集約する。同じ文字列が複数箇所にあっても宛先候補は同じ組とし，元の所在と証拠IDは保持する。既知のXML名前空間等は参照ヒントとして別保存する。動的側は正規化フローであり，静的宛先組と同じ単位ではない。

候補sと対象帰属のフローdの対応関係を，現在の実装では次で定義する。

$$R(s,d) = \text{target}(d) \wedge \text{valid}(d) \wedge (d.\text{transport} = \text{TCP}) \wedge (s.\text{port} = d.\text{port}) \wedge H(s,d). \quad (6)$$

validは取得失敗を表す記録でないこと，Hは候補が明示IPなら宛先IPの一致，ドメインなら記録ホスト名の一致である。ドメインをIPから推測せず，URLパス・スキームの実行成立・命令から送信へのデータフローまでは対応させない。従って，これは通信先候補の対応モデルであり，静的な送信経路の実行証明ではない。

候補側は，対応する対象フローがあれば「対応あり」，有効な取得がないか対応の可能性を残す帰属・ホスト不足があれば「判断不能」，残りを「静的のみ」とする。対応済みでない動的記録は，対象帰属・既知ホスト・静的処理完了を満たす場合に現在の規則で「動的のみ」とし，満たさなければ「判断不能」とする。別UIDは対象差分へ混入させず原本へ残す。TCP以外は対応規則の範囲外であることを説明に明示する。これらの分類は危険性や原因のラベルではない。

表 2: 単独情報と併用で説明できる内容の違い。性能の優劣を表す表ではない。

確認する内容	静的のみ	動的のみ	併用
APK内の候補と所在	確認可能	入力がない	確認可能
取得窓の通信・UID	入力がない	確認可能	確認可能
候補と実測の対応	実測不足	候補不足	条件の範囲で可能
差の原因の確定	一般には不可	一般には不可	補助証拠なしには不可

3.3 差分を説明する情報の分離

各対応表行rに対し，説明を$X_r = (F_r, G_r, H_r, N_r, E_r)$とする。$F_r$は候補・実測・比較処理から直接確認した事実，$G_r$は不足する情報，$H_r$は未確認の原因候補，$N_r$はこの結果から断定しない事項，$E_r$は証拠IDと出典の項目である。原因候補$H_r$を確認事実$F_r$に昇格させない。

`explanation.py`は，検証済み対応表から決定的なテンプレートでこれらを生成する。確認事実には`static.json`，`flows.jsonl`，`run.json`，`correspondence.json`の項目参照を付け，静的・動的事実には証拠IDを併記する。差分の原因を生成AIが自由記述で断定する処理ではない。例えば動的のみ行の「実行時入力の可能性」は未確認欄に残し，RSSの入力URLが記録で確認できたという事例解釈は，保存シナリオによる別の確認として述べる。

出力は`difference-explanation.json`とCSV，既存HTML内の説明欄である。元の対応表，静的・動的記録，任意ポリシーの判定は変更しない。説明の項目が埋まることと，原因の正解・利用者の理解を証明することは区別する。

3.4 使用文脈と追加観測による差分説明

静的候補と実測が対応しない場合，本研究は追加情報を二段階で調べる。まず，URLを受け取る対応APIの引数を基本ブロック内で追跡する。次に，登録済みのURI入力操作がある事

例では，入力先を切り替えた要求を観測する。第一段階はコード中の値の候補を，第二段階は入力と通信の観測上の対応を与える。両者を接続するコード実行経路の計測は別の証拠である。

説明対象と仮説　差分の説明候補には，固定値・文字列結合，明示的な実行時入力，保存済み設定・キャッシュ，その他の未解析処理がある。この分類は調査のための分類であり，排他的な原因分類器ではない。たとえば同じアプリは，入力したRSSを取得すると同時に既存購読を更新できる。

現在の選択器が扱う仮説モデルは，このうち登録した研究用要求についての次の2つに限定する。

$$H = \{h_{\text{input}}, h_{\text{fixed}}\}. \tag{7}$$

h_{input}は，正の要求が入力先に追随するモデル，h_{fixed}は，入力を変えても正の要求先が一定であるモデルである。Intent・設定・SDK等の原因を4分類する実装ではない。要求を観測できない場合には，いずれのモデルも残す。

入力と操作の選択　同一APKの基準試行に動的のみの記録があり，登録済みの`open_uri`操作が存在することを追加実行の前提とする。静的文脈で全動的のみ宛先を補える場合には，局所的な定数候補として提示する。残る場合に，URI切替と同一URI反復の2操作を比較する。操作pのコスト$c(p)$を端末試行数，仮説hの下で宣言した有効観測の集合を$O_p(h)$とすると，

$$q(p) = \frac{\sum_{\{h,h'\}\subseteq H} \mathbf{1}[O_p(h) \cap O_p(h') = \varnothing]}{c(p)}, \qquad c(p) \le B \tag{8}$$

で順位付けする。URI切替では「入力に追随」と「一定の要求先」，同一URI反復では両仮説とも「同じ入力での反復」を有効観測モデルとして宣言する。予算$B = 4$の今回の条件では，各コスト4に対しスコアはそれぞれ$1/4$，0となり，URI切替を選ぶ。これは事前に宣言したモデルの分離数による規則である。

URIは研究用ホスト`10.0.2.2`に固定し，OSが割り当てた異なる2ポートをA・Bとする。各試行のパスには別のUUID由来のnonceを付ける。宛先ポートの探索や情報利得の学習は行わない。順序はABとBAを組み合わせたABBA，起動待機5秒，URI入力後の観測30秒とする。ポートに加えてパスとRSSの自己参照先も変わるため，介入の単位は登録URI条件である。

入力追随を確認する基準　試行iの登録URIをu_i，その宛先をe_iとする。G_iは同一APK・インストール記録，起動とURI操作の完了，前後2件の取得対照，取得開始停止，原本整合性の確認とする。W_iは，対象UIDの完全なHTTP GETヘッダにu_iのnonceパスとe_iが現れ，サーバー記録と候補対応が成立することとする。サーバー側では同じパス，GET，200，書き込み完了を確認し，補正時刻差1秒以内を要求する。実装は単一パケット内の完全ヘッダを対象とする。

$$a_i = G_i \wedge W_i \wedge \text{scenario_matched}_i, \qquad A_{\text{input}} = [\text{order} = ABBA] \wedge \bigwedge_{i=1}^{4} a_i. \tag{9}$$

A_{input}が成立した場合の出力は`input_endpoint_association_observed`である。これはh_{input}と整合する正の証拠を得たという意味で，競合仮説を消去する意味ではない。実装も`remaining_hypotheses`に両モデルを保存する。証拠不足時は`inconclusive`を出力する。一定宛先を自動的に原因確定する分岐は現ランナーにない。

対象要求とUID不明の別フローは併存できる。したがって上記の局所的成立と取得全体の品質は別に記録する。前後対照は取得経路を補強し，候補対応はnonce・宛先・UID・条件

付き時計補正で補強する。NATの接続対応，アプリ内で本文を処理した事実，未観測の完全性は別の確認事項となる。

3.5 任意ポリシーの明示性

カテゴリ k の意図 I_k は，禁止，許可集合，未指定のいずれかを取る。

$$I_k \in \{\text{deny_all},\ \text{allowlist}(L_k),\ \text{unspecified}\}, \quad L_k \neq \varnothing. \tag{10}$$

空の許可集合はdeny_allで表現する。allowlistと非空集合を要求し，deny_allと非空許可集合の併記を入力エラーとすることで，条件の意味を一意にする。未指定を暗黙の禁止へ変換しない。

3.6 部分情報に基づく判定

証拠の不足と条件の未指定を区別する。規則kの前提が成立することを$V_k(e)$，その明示条件に必要な比較が可能なことを$Q_k(I_k, e)$，比較可能な条件を満たすことを$M_k(I_k, e)$とする。通信規則の前提には取得失敗でないことと対象帰属を含み，静的宣言規則に通信UIDの前提を流用しない。判定は次の排他的な分岐で定める。

$$J(I_k, e) = \begin{cases} \text{not_evaluable} & \neg V_k, \\ \text{needs_review} & V_k \wedge I_k = \text{unspecified}, \\ \text{not_evaluable} & V_k \wedge I_k \neq \text{unspecified} \wedge \neg Q_k, \\ \text{mismatch_candidate} & V_k \wedge I_k \neq \text{unspecified} \wedge Q_k \wedge \neg M_k, \\ \text{consistent} & V_k \wedge I_k \neq \text{unspecified} \wedge Q_k \wedge M_k. \end{cases} \tag{11}$$

最後のconsistentは実装値consistent_with_observed_evidenceの略である。Q_kは規則の分岐に依存する。通信禁止では対象接続試行があればホスト名不明でも比較できる。一方，ドメイン許可リストでは必要なホスト根拠がなければ判定不能とする。実装の取得失敗・非対象帰属の除外，未指定の評価，宛先比較という順序に対応する。規則間の指摘を単一の優先度で消去せず，個別に保持する。整合は観測範囲での局所的な判断であり，アプリ全体の安全性ではない。

3.7 独立した観測軸

表3の軸を独立に保存する。単一の危険度スコアへ集約すると，「宣言だけの違い」と「対象アプリの実接続」の差，および未知情報が失われるためである。

表 3: 判定と観測情報の軸

軸	値・意味
verdict	不一致候補，観測範囲で整合，要確認，判定不能
observation	static_only，not_observed，connection_attempt，transport_established，tls_established，http_observed，capture_failed
attribution	target，other，related_candidate，unknown
content visibility	none，metadata_only，plaintext_available
run status	completed，partial，invalid，failed（現実装では主にcompleted/partial/failedを利用）

TCP接続試行，TCP成立，TLS成立，HTTP要求観測は異なる段階である。CONNECTはプロキシに対するトンネル作成要求であり，上流へのTLS成立や本文送信成功を意味しない。PCAPアダプタでは3ウェイハンドシェイクを確認した場合にTCP成立とし，単一セグメントのClientHelloからSNIが読めてもTLS成立へ昇格させない。

3.8 ホスト名照合と未知値

正規化関数 $N(h)$ はIDNのASCII変換，末尾ドットの除去，大小文字の統一，IPの標準表記化を行う。サブドメインの許可フラグを b とすると，照合は次で定義する。

$$M(h, d, b) = [N(h) = N(d)] \lor [b \land \neg \mathrm{IP}(d) \land N(h)\text{が}.N(d)\text{で終わる}]. \tag{12}$$

ドット境界が必要であり，example.comに対してbadexample.comは一致しない。許可要素はホスト，ポート集合，アプリケーションプロトコル集合を持つ。ポートのみからプロトコルを推定しない。プロトコルが制約されているのに値が不明なら判定不能とする。

同じIPを複数ドメインが共有することやDNSキャッシュがあることから，IPだけで許可ドメインの利用を肯定・否定できない。DNSからの対応付けが曖昧なら，ホスト名をnullとし理由を記録する。現PCAPアダプタはDNS応答からアプリ接続のホストを確定せず，直接見えるHTTP HostやSNIを利用する。

3.9 アプリ帰属

対象APKのpackageを p_A，そのインストールのUIDを u_A とする。ログのUID u_e が一致し，package情報と矛盾しない場合に対象候補とする。package名だけが一致してもUIDが不明ならunknownとする。再インストールでUIDが変わり得るため，u_A は実験ごとに取得する。

同じUIDを共有する構成，OSサービスへの委譲，外部ブラウザ経由の処理には限界がある。またSDKはアプリと同一UIDで動作し得るため，UID一致はSDK名への帰属を意味しない。別UIDの通信を単に無関係とせず，取得元の注記がある場合はrelated_candidateとする。

3.10 操作との時間的対応

ログ時刻 t_d は，測定した差分 Δ を用いてホスト基準に変換する。

$$t_h = t_d + \Delta, \qquad E(e) = \{u_i \mid t_i^{\mathrm{start}} \le t_h \le t_i^{\mathrm{end}},\ u_i\text{が成功}\}. \tag{13}$$

対応する操作IDは時間的な関連を表すのみで，因果関係を示さない。Home後区間は操作上の定義であり，OSの厳密なバックグラウンド実行状態と同一視しない。待機対照と反復を用いて代替説明を検討する必要がある。

3.11 未観測の条件

not_observedは，正常性が確認された観測系で，指定区間内に該当記録がなかった場合の限定的表現である。取得前後の対照不成立，欠落区間，操作失敗がある試行を「通信なし」の正解として集計しない。さらに，対照が成立しても観測ツールやアダプタの対応範囲外の通信は残る。

3.12 時刻の不確実性と実装範囲

前後の時計測定で得た幅を点補正の確かさと混同しない。今後の境界判定モデルとして，補正時刻の候補を$J_t = [t_d + \widehat{\Delta} - \varepsilon, t_d + \widehat{\Delta} + \varepsilon]$とする。操作区間に完全に含まれる場合を区間内，交わらない場合を区間外，境界と重なる場合を不明とする。操作時刻自体の誤差も含める必要がある。

現行の正規化は点推定を使い，前後測定に整合する定数差という条件をmetadataとpartial品質で保持する。上記の区間判定と観測中ドリフトの上限検証は未実装であり，今回の結果へ実装済みの性質として適用しない。異なる時計の単一イベントの差をRTTや時計差そのものとして使わない。

4 システム設計

4.1 構成とデータの流れ

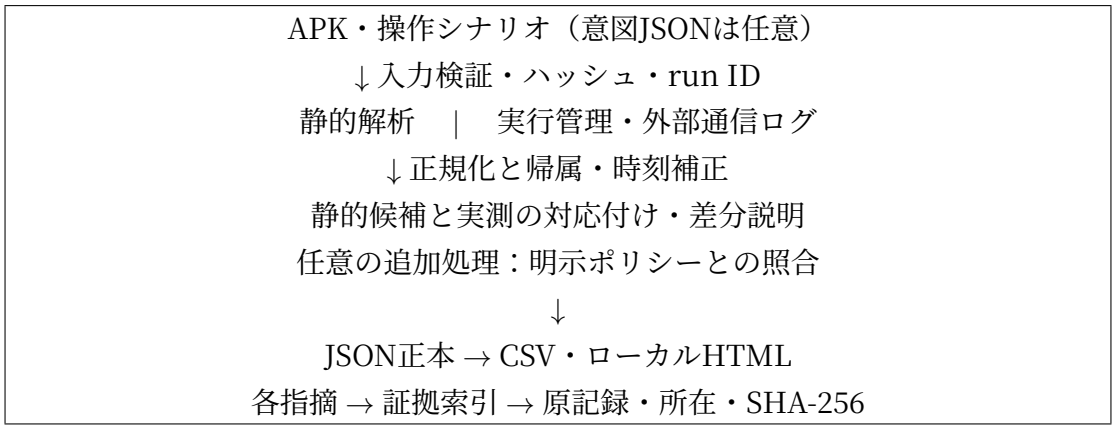


図 1: システムの処理構成。静的候補と動的観測は別の証拠として保持する。

入力検証器はスキーマ，APK形式，サイズ，矛盾を検査する。静的解析器は候補の抽出だけを担当し，禁止判定は照合器に分離する。観測アダプタは入力形式ごとの証拠を共通のフロー形式へ変換する。レポートはJSON正本から生成し，独立した判定軸を保存する。

4.2 記号と実装の対応

表 4: 理論モデルと実装モジュールの対応

記号・処理	実装上の対応
A, I, U, C	APK，intent，scenario，run/capture metadata
f_{static}	static.pyとworker。Manifest・DEX等の候補抽出
f_{capture}	automatic.py，補助APK，PCAPdroid，capture.py。過去試行は半自動ランナーとCSVアダプタ
g, J	compare.pyの規則別ポリシー照合
h：対応と差分説明	differential.pyとexplanation.py。対応表，確認事実・不足・未確認の原因候補の構造化
$q(p)$とA_{input}	research_diagnosis.pyのselect_probeとassess。操作候補の順位付けと入力追随の成立条件
証拠e	原本，evidence/index.json，core.py，report.py

従来のandroid.pyによるEmulator console PCAP経路は，本稿の半自動PCAPdroid実測とは別であり，端末実証済みとみなさない。

4.3 静的解析手順

処理の概要を以下に示す。

1. APKのサイズ，ZIPメンバーの名前，重複，展開量，Manifest・DEXの有無を検査する。
2. 元APKを改変せず保存し，SHA-256を計算する。
3. AndroguardでManifestを復号し，基本情報，権限，コンポーネント，通信設定を取得する。
4. すべてのclasses系DEXを走査し，文字列，クラス特徴，登録済みAPIへのinvoke命令を抽出する。
5. 選択したリソースとARSC文字列を走査し，URL候補の元値，正規化結果，所在を保存する。
6. SDKルールのclass接頭辞とManifest文字列を照合し，単一種類と複数種類の特徴一致を区別する。
7. 処理済みファイル，対象外ファイル，警告，失敗を出力する。

現在のSDKルールはFirebase Analytics，Google Mobile Ads，Facebook App Events，Sentry Androidの4種である。接頭辞一致は候補検出であり，バージョン確定，実行，到達可能性，通信主体を証明しない。AndroidX等の一般ライブラリを一括して禁止SDKと扱わない。

4.4 動的取得と操作管理

実装したADB連携は，明示選択されたローカルEmulatorを対象に，元APKのインストール，UID取得，パケット取得，UI操作，取得停止を管理する。現在のanalyzeでは，通常起動は対象packageの前面状態で確認し，tapにはresource-idと期待する到達先IDを指定する。現在の既定経路はアプリデータを保持し，一律のデータ消去や手動チェックポイントの自動承認は行わない。旧runの操作・初期化機能とは区分する。

現行経路はADBとPCAPdroidのCaptureCtrlを組み合わせる。取得前後に補助アプリから研究用HTTPサーバーへ要求し，応答，補助UIDのPCAP記録，取得開始停止を確認する。Mac arm64とAPI35 arm64のAVDで，自動HTTP，公開アプリ起動，RSS操作，URI切替を実測した。開発用Linux環境ではオフライン再解析を行った。旧Emulator console・ICMP方式は別の試作経路であり，本稿の自動取得の実証範囲は現行CaptureCtrl経路とする。

4.5 ログアダプタ

app-flowは本実装で定義したJSONL契約である。時刻，宛先IP・ポート，TCP/UDP，観測段階，任意のホスト名と根拠，UID，package，送受信量を入力する。加えて，PCAPdroid 2.0.2の固定ソースに基づくCSVアダプタを実装した。原CSVの行を証拠に保存し，列ずれや未確認の版を拒否する。表示状態から接続成立やTLS成立へ昇格させず，Info列からホストの出典を推定しない。Android実測のCSVは列契約と一致した。各試行の時計・取得対照・

APK同定の記録範囲をメタデータへ保存し，取得・時計の不確実性をpartialとして保持した。

PCAP/PCAPNGアダプタはクライアントIP側から通信方向を定める。60秒アイドルと新規SYNを区切りとしてフローをまとめるため，その件数は真の接続イベント数と一致する保証がない。TCP再構成やIP断片再構成は未実装であり，SNI・HTTP Hostの抽出範囲は限定される。PCAP単独のアプリ帰属はunknownとする。

同一ファイルの二重取り込みを拒否し，取得元IDを維持する。異なるログの一般的な接続同一性の確定は今後の課題である。研究用HTTPでは第3.4節の限定したサーバー候補対応を別に求める。取得元を横断した単純合計は避け，フローとサーバー要求を別の単位で保存する。

4.6 補助機能のポリシー照合規則

表 5: 実装した照合の基本規則

ID	対象	判定の考え方
C01	通信禁止	対象アプリの接続試行を不一致候補とする。接続成立・本文送信とは区別。
C02	通信先許可リスト	帰属，ホスト，ポート，取得できるプロトコルを比較。不明をリスト外とみなさない。
C03	SDK	登録ルールで検出した候補を意図と照合。初期化・送信は断定しない。
C04	権限	Manifest宣言を比較。実際の権限行使やデータ取得を意味しない。
C05	平文	設定上の許可と実際に観測した平文プロトコルを別指摘にする。
C06	Home後通信	成功した操作区間内の対象通信を比較。因果やSDK起因を断定しない。
C07	不足と未指定	条件未指定は要確認，帰属・解析・観測の不足は判定不能として残す。

4.7 証拠の管理と再現性

各runにはAPKのハッシュ，入力条件，版，ホスト情報，操作時刻，取得条件，エラーを保存する。原記録，正規化結果，照合結果を分離し，指摘から証拠ID，原ファイル，レコード位置，ハッシュへ到達できるようにする。レポート生成時に原ファイルのハッシュを再確認する。

ハッシュは保存後の変更検出と入力同定のためのもので，第三者がログを作成した事実や真実性を証明する電子署名ではない。取得系の対照やオフラインUID情報の自己申告には，原記録の保管と実験者による検証が必要である。

依存ライブラリは間接依存を含め版とハッシュを固定する。静的解析の再現性比較では，run ID，時刻，所要時間を除く候補・所在・規則版を比較する。動的結果にはOSスケジューリング，ネットワーク応答，初回同意，キャッシュ等が影響するため完全一致を要求しない。

5　実装と利用方法

5.1　実装環境とモジュール

検証した環境はLinux x86_64，Python 3.12.14である。主要ライブラリはAndroguard 4.1.3，jsonschema 4.25.1，dpkt 1.9.8，defusedxml 0.7.1である。プロジェクト版は0.1.0，ルール版は2026-10-27.1である。

表 6: Pythonモジュールと責務

モジュール	責務
core / contracts	時刻・ハッシュ・JSON入出力・スキーマ・正規化
static / worker	APK解析と子プロセスの隔離・資源制限
automatic / pcapdroid	実測済みのADB指定操作とPCAPdroid自動制御・UID拡張PCAP
capture	app-flowとPCAPの正規化・帰属・証拠索引
differential / explanation	対応表と構造化した差分説明
compare	任意ポリシーとの照合，独立した判定軸
report / share	CSV・HTML，原本を含まない共有用要約
cli / demo	コマンド操作，合成デモ

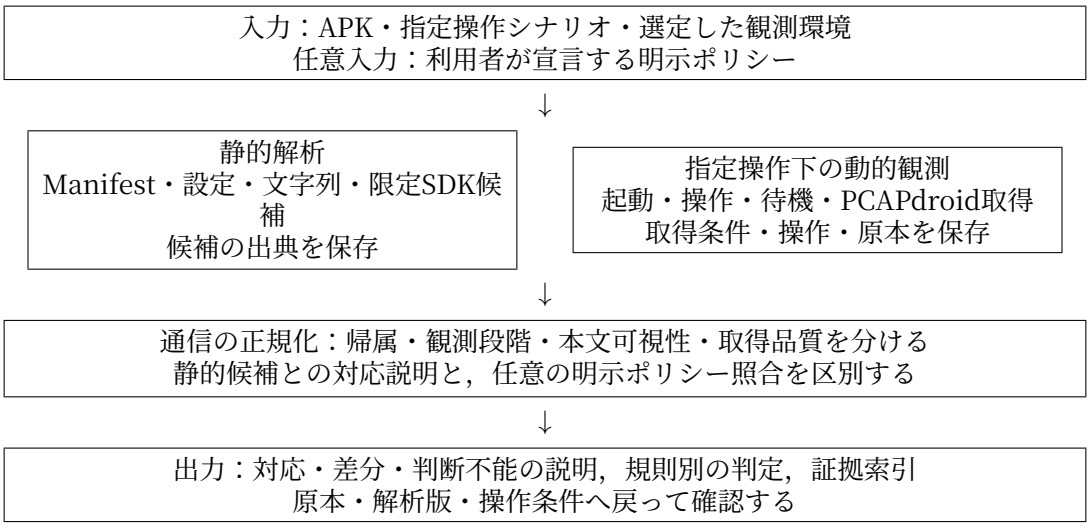


図 2: 本システムが担当する処理の範囲。指定操作は全機能探索ではない。同意画面は実施者が確認する。サーバー記録とUIによるケース検証は，一般的な自動結合・全入力監視とは区別する。

5.2　標準的な実行例

現在の主入口は`apk-audit analyze`である。APK，選定済み端末，必要に応じた操作シナリオから，静的解析・指定操作・PCAPdroid開始停止回収・正規化・任意照合・差分説明を連続実行する。制御・VPNの同意画面は実施者が確認する。シナリオ省略時は起動と待機のみであり，全画面の探索ではない。

```
source .venv/bin/activate
apk-audit analyze --apk app.apk --serial emulator-5554 \
  --out runs/app-001
open runs/app-001/summary.html
```

操作を固定する場合は--scenario scenario.json，任意ポリシーを追加する場合は--intent intent.jsonを指定する。保存済み取得は--captureと--metadataで再解析できるが，新しい端末試行とはしない。出力のcorrespondence.jsonが分類，difference-explanation.jsonが確認事実・不足・未確認原因候補を保存する。初期のCSV実験では半自動ランナーを使っており，現在の自動経路で全25試行を取得したとは記述しない。

5.3 使用文脈解析とURI対照ランナー

URL・URI生成，OkHttpの文字列URL設定，WebView.loadUrlの4シグネチャを対象に，DEXの基本ブロック内で文字列定義・コピー・限定した結合を追跡する。元のAPK解析結果に加えて，引数候補と命令位置を別出力に保存する。解析の境界を越える値は不明とする。公開APKの対象29箇所では定数URL2，不明27を得た。定数2箇所はプロキシ試験用のhttps://www.example.comとライブラリ初期値のhttp://undefined/である。不明27箇所のruntime_originsはすべて空であり，Intent由来と同定した結果ではない。この解析範囲と実行時入力経路の関係は分けて解釈する。

ランナーは第3.4節の前提・選択規則・成立基準を実装する。research_contextが引数追跡，research_diagnosisが計画選択と証拠条件の点検，research_contrastがURI入力と研究用サーバーを管理する。各試行のAPK・シナリオ・コードhash，前後対照，要求の候補対応を保存する。結果を表7に示す。

5.4 資源制限と入力保護

初期値はAPK上限200 MiB，ZIP内の宣言展開量1 GiB，静的解析10分，動的1試行10分とする。Linuxでは静的ワーカのアドレス空間を3 GiBに制限する。DarwinではRLIMIT_ASの互換性に制約があるため，この制限を適用せず，親の時間上限・APKサイズ・パーサの入力上限を使い，実際の適用状況を記録する。これらは入力保護の設定値である。リソース単体が8 MiBを超える場合は対象外とし，未処理範囲に記録する。

ZIPメンバーの絶対パス，親ディレクトリ参照，危険な区切り，重複を検査し，入力名のまま展開先パスを作らない。JSON文字列をshell命令として実行せず，引数配列を用いる。HTMLはエスケープし，外部資源に依存しない。CSVでは先頭の式記号を無害化する。

子プロセスと資源制限は被害範囲を抑えるが，解析ライブラリの脆弱性を完全に防ぐサンドボックスを実装したものではない。未知APKを扱う研究環境自体も隔離する必要がある。

5.5 記録保護と共有版

研究者用の原本にはトークンや個人情報を含み得るURL・ログが残る。共有版は許可された判定項目だけを抽出し，目的文，ホスト，パス，UID，原本ログ，証拠リンクを省く。これを完全に匿名化した原本や根拠付きレポートとは呼ばず，「証拠を含まない共有用要約」と区別する。

6 評価方法

6.1 研究課題

RQ1 APK入力から比較説明までを実行し，実施した操作，指定した条件，失敗した段階と根拠を保存できるか。

RQ2 静的候補と実測を対応付けると，対応あり・静的のみ・動的のみ・判断不能の各事例が何を示し，単独の情報とどう異なるか。

RQ3 URI入力先の切替に対して対象要求が追随することを，記録された成立基準で確認し，動的のみの差分説明を補強できるか。

SDK候補抽出や手作業量は補助的な評価項目とする。実SDKや被験者作業の独立した正解を得るまで，検出精度や時間削減を主要成果としない。

独立した人手正解は未取得であり，AI点検と実装上の受入確認を独立評価へ置き換えない。準備済みの未注釈票は研究台帳へ保存し，評価結果から分ける。

6.2 研究デザインとデータの範囲

主結果はAntennaPodへのURI入力切替4試行である。同一APK・同一AVD上で入力を変え，登録条件に対する要求先の追随を確認する。既存25試行は，CSVによるHTTP・UDP・通信なし・HTTP処理不成功・HTTPS，および自動HTTP・公開起動・RSSの補助事例として位置付ける。最終構成は付録の表12に統一した。

全体は29試行の事例研究であり，独立したアプリ数は公開アプリ1本と開発用制御素材に限られる。既存25試行の対象あり19・不明候補4・いずれもなし2と，追加4試行の対象あり4・不明併存1を区別する。全品質はpartialで，方式比較や再解析は試行数に加えない。URI計画は取得前に保存され，本稿の全体比較と説明整理は事後解析として明示する。

6.3 比較する入力と手法

静的のみはAPKの静的結果，動的のみは通信と取得・インストール・操作の共通情報，併用は両者の和集合を用いる。同じAPK・原本・解析規則で，支持できる事実と不足する根拠の差を調べる。サーバー原本やUIは検証の補助資料として区別し，併用だけへ与えた人手情報の効果を方式の優位性とはしない。限定HTTP本文のケース検査も，メタデータ解析本体の機能と区別する。

UID条件の比較では，不明保持・不明行削除・UID条件だけを除去した方式を同じ記録へ適用する。これは構成要素の事後比較であり，実際の外部ツールの挙動や独立した正解への誤検出率ではない。事後の禁止・未指定ポリシーは取得前条件とは区別して表示する。3方式比較済みの制御19試行では動的のみと併用の選定通信の判定・状態が一致し，併用による判定精度改善を主張しない。

6.4 評価単位と指標

端末試行，静的候補，正規化フロー，宛先組，HTTP要求・応答，本文照合を別単位とする。観測記録の存在，帰属・可視性・取得品質，静的動的の対応，参照先の所在・hashと事実への支持を確認する。hash一致だけで説明の意味が正しいとはしない。判定不能率等を集計する場合も，どの選定記録を分母としたかを示す。

独立した真値がないため，一般的な適合率，再現率，UID帰属精度，手作業削減率は本稿の主要結果として算出しない。同一AVD反復からアプリ母集団への有意差を求めない。構成要素の比較による「未支持」は，独立に事実誤りが反証された意味ではない。分母0と人手未注釈は未定義・未評価として残す。

6.5　開始状態と操作記録の扱い

RSS001は実施者が購読・再生等を報告した混合操作の事例，002・003は開始前記録がなく追加操作なしと申告された事例として扱う。006では開始前の購読一覧・UI階層・前景情報と，終了後の追加操作なし申告を保存できた。以前の研究用フィードが残っており，空の初期状態とはしない。可視画面はデータベース全体ではなく，自己申告は全入力の客観的監視ではない。

この記録により試行条件を追跡できる一方，試行間の差を特定操作の因果効果とはしない。UID保持不具合の訂正や追加操作の申告は原本外の解析版・検証記録で追跡する。受領原本を上書きして結果を整えることはしない。

6.6　妥当性への脅威

内的妥当性　初回同意，アプリデータ，権限，キャッシュ，時刻ずれ，サーバ応答が差の原因になり得る。反復と待機対照，条件の保存で検討する。操作直後の通信という時間関係だけで因果を断定しない。

構成概念妥当性　URL文字列数は通信数の代理にならない。許可先への通信は安全の代理にならない。SDK候補とSDKによる送信も別の概念である。評価単位を事前に固定する。

外的妥当性　単一API/ABI，少数の自作アプリ，4種のSDKルールから他アプリ全般へ一般化できない。難読化，動的ロード，ネイティブ実装，ログインが必要な機能を限界に残す。

評価者の偏り　解析器の出力だけで正解表を作らない。ルール調整用と評価用素材を分ける。独立評価者を確保できない場合は，同一人物が正解表と評価を作成したことを明記する。

6.7　差分説明の確認基準

保存済み入力を新しい作業先へコピーし，対応表と構造化説明を生成する。試行ごとに訂正済み対応件数の維持，説明行と対応表行の一致，確認事実のファイル・項目参照，証拠IDの存在・hash，原本非変更を確認する。これらは実装上の受入基準であり，説明が利用者に理解される割合や原因推定精度の基準ではない。未知原因を原因候補へ残すことを仕様とし，自動的に正解原因と採点しない。差分規則の分岐は，合成入力で取得失敗・UID不明・ホスト不足・通信方式制約を個別に検査する。合成入力のテストを新しい端末実験へ数えない。

7　評価結果

7.1　局所的な静的引数追跡の結果

対応APIの引数29箇所のうち，定数として復元できたのは2箇所，不明は27箇所であった。この結果は基本ブロック内追跡の解決範囲を示す。Intent由来のタグを持つ箇所は0である。したがって，不明27箇所をRSS入力経路へ一括対応させる根拠にはせず，登録したURI操作と実測要求を追加の証拠として調べた。

7.2　URI入力切替による要求先の追随

4試行すべてで，対象UIDの要求先ポートは入力ポートと一致し，A・Bの切替に追随した。Aは2試行とも59521番，Bは2試行とも59522番であった。表7に入力と観測の対応を示す。各試行で前後の取得対照が成立し，第3.4節の入力追随基準を満たした。

表 7: URI切替の主結果。同一APK・同一AVDでの反復確認。

試行	入力	入力ポート	観測ポート	HTTP	GETパケット
1	A	59521	59521	200	43
2	B	59522	59522	200	55
3	B	59522	59522	200	53
4	A	59521	59521	200	39

対象はAntennaPod 3.12.3で，入力順序ABBA，起動待機5秒，URI操作後30秒の計画を用いた。入力先以外の既存アプリデータは保持した。各試行のパスは別のnonceを持つ。対象UID10213の要求と，そのnonceを持つサーバー受信記録の候補対応を確認した。保持したHTTP 200応答には各184 Bの本文があり，配布版サーバー仕様から再構成したRSS本文と一致した。

全試行の静的候補は同じ38宛先組で，対象要求先への対応候補はなく，対象フロー1件が「動的のみ」となった。入力を変えても静的候補は同じである一方，実測した研究用要求先は入力とともに変わった。これにより，この差分を「抽出候補にない通信」と表示する段階から，「登録入力先に追随する要求を確認した」と説明する段階へ補強できた。

記録の整合性と不確実性　静的結果・全フロー・規則判定・対応表・診断を保存原本から再計算し，対象出力が再現した。3試行目には別にUID不明のUDP/443が1フローあり，対象アプリへ補完せず判断不能として保存した。1試行目では停止統計123パケットに対し保存PCAPが124パケットであり，末尾の対象外UDP1パケットの差を記録した。原因は未確定で，取得全体の品質partialを維持した。

観測は入力先と要求の対応を支持する。ポート，nonceパス，RSSの自己参照先がともに変わり，開始状態の復元は実施していないため，単一要因の効果や実行コード箇所の確定は別に扱う。追加操作なしは取得後申告として保存した。条件内の反復確認を，アプリ母集団への精度推定へ広げない。

7.3　静的・動的差分を中心とした再解析

既存25試行を新しい作業先へコピーし，対応表の各行に確認事実，不足情報，未確認の原因候補，断定しない事項と原本参照を付加した。公開起動は訂正済みUID版を使用した。25試行すべてで従来の訂正済み対応件数を維持し，参照原本も変更していない。これは説明形式と出典参照の実装確認であり，原因推定精度や利用者の理解向上の独立評価ではない。

表 8: 主要事例の差分分類。件数は対応表の行数であり，通信回数ではない。

事例	対応あり	静的のみ	動的のみ	判断不能
自動HTTP	1	1	0	0
公開アプリ起動	0	38	0	0
RSS001	0	38	3	0
RSS002	0	38	2	0
RSS003	0	38	2	0

事例	対応あり	静的のみ	動的のみ	判断不能
RSS006	0	38	2	0

自動HTTPでは静的2候補のうち1候補に対象通信が対応し，残る1候補は取得範囲で未対応だった。公開起動では候補38組がある一方，対象UIDの通信は未観測だった。RSS006は静的38組と対応しない実測2フローを得たが，2フローは1宛先の記録であり，静的38組との差を算術的に引く対象ではない。研究用URLが実行時に与えられた事実は保存シナリオで別途確認する。一般の動的のみ行に対して実行時入力が原因であると自動断定するものではない。

7.4 対応と差分から得られた説明

自動HTTPの対応ありは，APK内の明示IP・ポートと対象UIDの通信が一致した事例である。残る静的候補は資料参照用のリソースに由来するが，未使用コード一般の判定を意味しない。公開起動の対象未観測は，起動操作だけではRSS機能の通信を代表しないことを示す。RSSの動的のみは実行時に研究用URLを指定した条件と両立し，候補の外に現れたことだけで不正通信とは判断できない。RSS006のGET応答本文679 Bと音声HEAD本文0 Bは原本の別途検査で確認し，2フローと3要求，1宛先を区別した。

差分レポートの本文は規則から決定的に生成する。「実行時入力」「未操作機能」「取得漏れ」等は一般行の原因候補であり，確認事実とは別欄に置く。特定事例でシナリオとサーバー記録を照合した説明は，本体が原因を自動発見したこととは区別する。UDPのUID不明と保持時の帰属差は，版・本文長等の交絡があるため，保持時間の因果効果とはしない。

表 9: RSS006を例にした差分説明の読み方。最後の事例解釈は別途の原本点検であり，自動推論の正解率ではない。

説明の段階	内容
静的側の事実	抽出URLをホスト・ポートで集約した38組に，入力した研究用宛先と対応する候補がない。
動的側の事実	UID10213の2フローが同じ研究用IP・ポートに向かう。取得品質はpartial。
対応表の結果	現在の対応規則では動的のみ2行。38と2の差を欠落件数にはしない。
一般の原因候補	実行時入力・組み立て・設定・解析範囲外等の可能性。ここだけでは確定しない。
事例としての補強	保存シナリオに研究用RSS URLの入力があり，保持パケットにGETとHEADがある。
残る限界	同じURLを生成したコード箇所，全文のアプリ内消費，全操作の網羅は未確定。

7.5 併用と補助的な照合の結果

元の取得条件で3方式比較済みなのは制御19試行・57出力であり，動的のみと併用の選定通信判定・状態は19試行で一致した。ポリシー判定精度の改善を結果に含めず，静的候補と実測の違いを説明する機能と区別する。帰属不明4単位の保持・削除・UID条件除去の事後比較では出力が変化したが，独立した正解に対する誤判定率ではない。これは差分説明の前提となる帰属情報を保持する設計の補助確認である。

7.6　点検と一般化の範囲

既存25試行の保存入力から規則判定を再生成し，保存出力と整合した。自動HTTP・公開起動・RSS001・RSS006は原本と説明を詳しくAI支援で点検した。公開起動の旧版UID欠落を訂正し，RSS001の追加手動操作，RSS006の既存購読状態を明記した。単一AVD，公開アプリ1本，全取得品質partial，独立人手正解なしという範囲は維持する。方式比較・AI点検・今回の差分説明生成の再実行は，端末試行数を増やさない。

8　考察と制約

8.1　静的候補・実測・入力切替が担う役割

静的解析はAPK内の候補と所在を，動的解析は指定操作下で観測した通信を与える。両者の対応表により，自動HTTPでは候補と実測の一致，通常起動では候補があっても対象未観測，RSSでは候補にない実測という違いを同じ形式で説明できた。

URI切替では，静的候補を変えずに入力先を変え，対象要求がA・Bそれぞれに追随した。これは，動的のみという表示を入力条件との対応によって補強した結果である。局所的な静的引数追跡は候補の復元範囲を示し，追加観測は登録入力と実測の関係を示す。ただし，不明27箇所のどれがRSS要求を実行したかは計測していない。このため，両結果を同一コード経路の証明として連結せず，異なる種類の根拠として併記する。

8.2　取得の不確実性を残す意義

対象UID要求を確認した試行にも，別のUID不明フローや停止統計との差が併存した。対象要求の局所的な確認と，取得全体の完全性を別に記録することで，肯定的な結果を保持しながら不足する範囲も確認できた。既存の不明候補4単位についても，保持・削除・対象UID条件の除去により出力が変わった。これらは情報を保持する設計の処理結果であり，未知アプリに対する誤検出率とは別の評価である。

8.3　比較から確認できた範囲

制御19試行で実施した静的のみ・動的のみ・併用の比較では，動的のみと併用の選定通信判定が一致した。現在確認できる併用の価値は，通信判定の変更ではなく，APK内の候補・権限・通信設定と実測を併記し，対応と不足を説明することである。

追加ランナーの選択候補はURI切替と同一URI反復であり，今回選ばれた順序は固定ABBAと同じである。固定ABBA方式と適応的な方式の効率比較は実施していない。したがって，本稿の成果は入力切替を自動実行し，所定の証拠条件で追随を確認したこととして報告する。

8.4　妥当性と次に確かめること

表 10: 本事例評価の範囲と次の確認事項

観点	現在の範囲	次の確認
入力介入	URI条件を切り替え，要求先の一致を4試行で確認。	状態を固定し，追随しない対照を含める。

観点	現在の範囲	次の確認
静的文脈	4 API・基本ブロック内で定数2，不明27。	由来追跡と実行経路を別に照合する。
帰属・取得	収集器UIDをインストール記録と照合。全品質partial。	独立した帰属手段と欠落検査。
正解・評価者	ソース仕様・原本・AI点検による確認。人手票は未注釈。	開発用と別の素材・第三者確認。
一般化	単一AVD，公開アプリ1本。同条件内の反復。	入力機能を持つ別の公開アプリ。
新規性	差分説明と追加観測を結ぶ具体的な実装・事例。	差分通信解析・能動的診断の先行手法と比較。

今後の評価では，文字列抽出，文脈解析追加，固定追加実行，証拠に基づく追加実行を，同じ観測予算で比較する。正しい説明の確認数，保留，誤断定，実行数と時間を同時に記録する。説明対象と正解根拠を評価前に固定し，結果を見て有利な事例だけを選ぶことを避ける。キャッシュや保存設定が要求を固定し得る条件では，要求不在をその機構の証明とせず，別の正の証拠を必要とする。

9　結論

本研究は，Android APKの静的解析と指定操作下の動的通信解析を連携し，候補と実測の対応・差分を根拠付きで説明するシステムを実装した。対応表，取得条件，確認事実，不足情報，原因候補を分けることで，静的候補と実測が示す範囲を読み分けられる構成とした。

主結果として，AntennaPodのURI入力をABBAで切り替えた4試行すべてにおいて，対象要求先が入力先と一致した。静的候補にない通信を，登録した入力条件に追随する要求として実験記録から説明できた。局所的な引数追跡で得た定数2・不明27という解析範囲と，この観測上の対応を区別して示した。

既存25試行は，HTTPの対応あり，公開起動の未観測，RSSの動的のみ，UID不明と処理不成功の補助事例として整理した。本研究の結論は，静的・動的の差分に追加観測を結び付けたシステムと，選定環境での説明の補強である。複数アプリへの一般化と，固定方式に対する説明品質・効率の比較を次の課題とする。

10　倫理とデータ管理

解析・実行の許可がある研究用APKとAVDを用い，位置情報等はダミーデータとする。原本ログ・画面には個人情報や認証情報が含まれ得るため，研究者用保管と共有用集計を分ける。公開成果物には原本の全文を追加せず，必要な集計・所在・hashを保存した。これを完全な匿名化や第三者による真実性の保証とはしない。外部SDK・公開素材・生成コードを追加する場合は利用条件を確認し，実装，テスト・解析補助，文章構成・草稿・推敲に生成AI支援を使用した。使用範囲と検証責任を付録に記録し，所属機関・投稿先の規定に合わせて開示する。

A　素材同定と実装確認

A.1　APKと環境の同定

公開アプリはF-Droid配布のAntennaPod 3.12.3，packageは`de.danoeh.antennapod`である。使用したAPKのSHA-256を以下に示す。

```
6e79f28f69cef1a8b2e4f5f88c9c3cf3c3d7c51356f01394ac23b0dc5d56a00b
```

AndroidはAPI35，ABIはarm64-v8aで，AVD名は`Pixel_8_Edited_API_35`，実行時serialは`emulator-5554`である。build fingerprintは次の値である。

```
google/sdk_gphone64_arm64/emu64a:15/AP31.240517.022/11948202:userdebug/dev-keys
```

実行ホストはmacOS 27.2 arm64，Python 3.11.9，ADB 35.0.1，収集器はPCAPdroid 2.0.2である。開発用LinuxではAndroguard 4.1.3，dpkt 1.9.8を用いて原本を再解析した。API35は自作素材のビルド条件と実行AVDをそろえる固定条件であり，Android全版の代表として選んだものではない。

初期の静的処理確認にはAndroguard公式リポジトリの`tests/data/APK/hello-world.apk`も用いた。取得元コミットは`581f7a3251545a97f66ee92b674dd810ee380a00`，サイズは1,722,314 bytes，SHA-256は次の値である。

```
f427a0ebe0bca97b9acf6cd2a2a01c37a7d3762841810fc54a7191ec637330b2
```

静的URL候補202件，登録API参照41件，登録SDK候補0件を得た。これらは所在別の抽出件数であり，実通信や実SDKの精度値とは区別する。このAPKの端末実行は本稿の29試行に含まない。

A.2　開発用の静的確認

通信なし，HTTP，HTTPS，UDP，位置取得のみ，位置取得とHTTPS，遅延，Activity非表示後，クラッシュ，複数DEXの10素材を作成し，生成仕様と解析結果を103項目で照合した。パッケージ名はaapt2とも照合した。開発過程で作成した素材・期待値を用いる回帰確認として扱う。 模擬Sentryクラスは接頭辞ルールの確認用であり，実SDK正例から除外する。引数文脈の6ケースでは実DEX上の定数・限定結合・分岐・実行時入力等を確認した。自動テストとこれらの開発用確認は，端末試行や未見アプリの精度標本と別に管理する。

表 11: 自作素材の静的確認。時間は各1回の例。

Case	Checks	URLs	API refs	Time (s)
offline	10/10	2	0	0.92
http	10/10	3	12	0.72
https	10/10	2	12	0.47
udp	10/10	2	6	0.52
location_only	10/10	2	2	0.52
location_https	10/10	2	16	0.37
delayed	10/10	3	12	0.53
after_home	10/10	3	12	0.52
crash	10/10	2	0	0.37
static_multidex	13/13	3	1	0.37

B　最終台帳と取得範囲

B.1　最終データ構成

表12に最終状態をまとめる。対象記録と不明候補は試行内で併存できるため，別列の指標とする。取得原本と解析版の経緯は研究台帳に保存し，本稿の集計はこの表に統一する。 全試

表 12: 最終29試行の構成。対象・不明は該当記録を含む試行数。

条件・取得経路	試行数	対象あり	不明候補あり
HTTP・CSV	4	4	0
通信なし条件・CSV	1	0	0
短時間UDP・CSV	4	0	4
保持UDP・CSV	4	4	0
HTTP処理不成功・CSV	3	3	0
専用信頼HTTPS・CSV	3	3	0
自動HTTP・PCAP	1	1	0
公開アプリ起動	1	0	0
RSS・購読再生等の追加操作	1	1	0
RSSプレビュー	3	3	0
URI切替（追加群）	4	4	1
合計	29	23	5

行はAPI35・arm64の単一AVDで取得し，品質をpartialとして保存した。既存25試行の相互排他的な内訳は対象あり19，不明候補4，いずれもなし2である。追加4試行には全て対象記録があり，うち1試行には別に不明フローがある。上表の対象23と不明5は重複を含む列であり，両列を足して無通信試行を推定しない。

B.2　確認済み範囲と拡張課題

表 13: 取得経路と機能の最終確認範囲

項目	確認済み	拡張時の確認事項
ADB・自動取得	MacのAPI35 AVDで自動HTTP，公開起動，RSS，URI切替。CaptureCtrlと前後HTTP対照。	別AVD・実機・収集器版。
HTTP	対象UID要求，制御サーバー記録，URI4試行の200・保持本文。	分割ヘッダ・一般TCP再構成。
HTTPS	専用信頼設定のAndroid制御APKで3試行。CSVとアプリ・参照サーバーの記録。	一般アプリのTLS・ピンニング。
HTTP処理不成功	Androidで3試行。対象接続試行とアプリのSocketTimeoutException。	失敗原因別・TLS失敗の分類。
UDP	短時間と保持条件の実記録。UID不明と既知UIDを保存。	同一APKで保持時間だけを変えた比較。
静的文脈	対応4 APIの基本ブロック内追跡。公開APK29箇所と開発用DEX。	ブロック・メソッドをまたぐ追跡。
操作・初期状態	シナリオ・時刻・終了後申告。RSS006は開始前画面。	状態復元・入力の独立監視。

項目	確認済み	拡張時の確認事項
旧 Emulator console	試作実装を保存。現行取得結果と区分。	この経路自体の端末評価。
Home後・遅延等	素材と解析分岐の開発用確認。	対応する端末条件の評価。

C 再現資料とAI支援の記録

原APK，PCAP，CSV，UI・サーバー記録とインデックスを研究者用に保管し，公開資料には集計と再生成ソースを収録する。実行記録のインデックスとhashを確認してから，別作業先で正規化・照合・説明を再生成する。公開起動のUID訂正，RSS001の追加操作，RSS006の既存購読，URI4試行の統計差を現行台帳に反映した。時系列の受領・配布履歴は本文から研究台帳へ移した。

論文のTeX，最終29試行CSV，URI4試行の集計，主張と証拠範囲のJSONを公開する。原本再解析には研究者用の入力と依存環境を必要とする。外部へ出す原本は，利用許諾と機微情報を個別に確認して選ぶ。

ChatGPT/Codexによる実装，テスト設計・不具合修正，解析補助，文章構成・草稿作成，翻訳・推敲の支援と，研究者が提示したClaudeによる草稿レビューを使用した。AIの出力は実装ソース・保存記録との照合により点検した。AI点検を第三者による独立した正解付けと区別する。所属機関と投稿先の規定を確認し，提出時に実際の製品・利用日・利用範囲と著者の確認責任を確定して記載する。AIは著者とせず，著者情報・共著者・謝辞は研究者と指導教員が確定する。

参考文献

[1] Androguard project, “Getting Started” and official repository. https://androguard.readthedocs.io/en/latest/intro/gettingstarted.html; https://github.com/androguard/androguard. 実装では4.1.3を使用。

[2] Android Developers, “Network security configuration.” https://developer.android.com/privacy-and-security/security-config.

[3] Android Developers, “Start the emulator from the command line.” https://developer.android.com/studio/run/emulator-commandline.

[4] Emanuele Faranda et al., “PCAPdroid,” official repository. https://github.com/emanuele-f/PCAPdroid.

[5] Android Developers, “Set up Proxy with the Android Emulator.” https://developer.android.com/studio/run/emulator-networking-proxy.

[6] mitmproxy project, “Protocols.” https://docs.mitmproxy.org/stable/concepts/protocols/.

[7] mitmproxy project, “Install System CA Certificate on Android Emulator.” https://docs.mitmproxy.org/stable/howto/install-system-trusted-ca-android/.

[8] FlowDroid project, “FlowDroid Data Flow Analysis Tool,” official README, commit 9bf10349ec6fdceebbcfda2d261a1f23b9e2e439. https://github.com/

secure-software-engineering/FlowDroid. 公式実装資料を確認。査読論文本文の引用ではない。

[9] LibScout project, official README, commit 8c0bd2c147e818841fc695eecb1246e38458435f. https://github.com/reddr/LibScout. 公式実装資料を確認。

[10] PCAPdroid project, "ConnectionsAdapter.dumpConnectionsCsv," "ConnectionDescriptor," "Utils," and "strings.xml," commit 66f7b3514540c20add8655a74dfee93d00a9563b, versionName 2.0.2. https://github.com/emanuele-f/PCAPdroid. 固定ソースのCSV契約を確認。初回Emulator出力との列一致を確認したが，帰属精度評価は未実施。

[11] PCAPdroid project, "FAQ," official user guide, gh-pages commit fe15479b1372214edd354a7095092c4dbee88077. https://github.com/emanuele-f/PCAPdroid/blob/fe15479b1372214edd354a7095092c4dbee88077/faq.md. 2026年10月29日確認。

[12] PCAPdroid project, "CaptureService.getUidQ" and "uid_resolver.c," commit 66f7b3514540c20add8655a74dfee93d00a9563b, version 2.0.2. https://github.com/emanuele-f/PCAPdroid/blob/66f7b3514540c20add8655a74dfee93d00a9563b/app/src/main/jni/common/uid_resolver.c. 2026年10月29日確認。

[13] PCAPdroid project, "ConnectionOverview," same 2.0.2 source commit. https://github.com/emanuele-f/PCAPdroid/blob/66f7b3514540c20add8655a74dfee93d00a9563b/app/src/main/java/com/emanuelef/remote_capture/fragments/ConnectionOverview.java. 2026年10月29日確認。

[14] Y. Li, Z. Yang, Y. Guo, X. Chen, "DroidBot: A Lightweight UI-Guided Test Input Generator for Android," ICSE Companion, 2017. 著者公開本文を確認。https://github.com/ylimit/ylimit.github.io/blob/6a5166cfccb87933125a10fc2e6a93b8da2a790a/static/files/DroidBot_ICSE2017.pdf. 2026年11月3日確認。

[15] D. Bui, Y. Yao, K. G. Shin, J.-M. Choi, J. Shin, "Consistency Analysis of Data-Usage Purposes in Mobile Apps," ACM CCS, pp. 2824–2843, 2021. https://doi.org/10.1145/3460120.3484536. 著者公開本文の導入，5.1–5.2節，6.3節，8.1節，9節を確認。公開PDF: https://github.com/ducalpha/ducalpha.github.io/blob/23dcda0e9efa5bcffa0306cd4ad7dfc307a2af8c/files/ccs21-duc.pdf. 2026年11月3日確認。

[16] MobSF project, official README, commit 9c2c08645370f5e404abf9a5c68012daf6dfc433. https://github.com/MobSF/Mobile-Security-Framework-MobSF. 2026年11月3日確認。公式ツール資料であり，性能比較実験は未実施。

[17] B. Andow et al., PoliCheck official artifact, README and Consistency.py, commit 6c0c16300118ee17547ad7b9ecaf047aa674f463. https://github.com/benandow/PrivacyPolicyAnalysis. 2026年11月3日に公式成果物を確認。論文本文の確認は別掲の査読論文引用を参照。

[18] H. Cui et al., PoliGraph official artifact, README and flow_consistency_analysis.py, commit e93771156e223f902c3e5f42ea8d877d8fb239ef. https://github.com/UCI-Networking-Group/PoliGraph. 2026年11月3日に公式成果物を確認。論文本文の確認は別掲の査読論文引用を参照。

[19] B. Andow, S. Y. Mahmud, J. Whitaker, W. Enck, B. Reaves, K. Singh, S. Egelman, “Actions Speak Louder than Words: Entity-Sensitive Privacy Policy and Data Flow Analysis with PoliCheck,” 29th USENIX Security Symposium, pp.985–1002, 2020. 提供PDFの関連節を2026年11月5日に確認。掲載ページ：https://www.usenix.org/conference/usenixsecurity20/presentation/andow.

[20] H. Cui, R. Trimananda, A. Markopoulou, S. Jordan, “PoliGraph: Automated Privacy Policy Analysis using Knowledge Graphs,” 32nd USENIX Security Symposium, pp.1037–1054, 2023. 提供PDFの関連節を2026年11月5日に確認。掲載ページ：https://www.usenix.org/conference/usenixsecurity23/presentation/cui.

[21] Agrigento project, official README, commit 0ce537d594937bc4fc724933f501da72818a07d2. https://github.com/ucsb-seclab/agrigento/blob/0ce537d594937bc4fc724933f501da72818a07d2/README.md. 2026年11月6日確認。Andrea Continella et al., “Obfuscation-Resilient Privacy Leak Detection for Mobile Apps Through Differential Analysis,” NDSS 2017の公式成果物。引用範囲はREADMEの方式説明であり，論文本文の確認ではない。

[22] AntMonitor project, official README, commit 01f09829cbe6388cbe43582f57defc805b912362. https://github.com/UCI-Networking-Group/AntMonitor. 2026年11月6日確認。端末上VPN取得・検査とライブラリの説明を確認。

仕様URLの一部は添付要件書から引き継いだもので，本文の再確認とアクセス日の確定が残る。今回確認した公式FAQ・UID照会・Durationの実装には確認日を付した。オンライン資料は更新され得るため，卒論提出時に利用API・採用版に対応する記述とアクセス日を再確認すること。APKの取得元とハッシュは付録A.1に記載した。